

Phishing Investigation Playbook

Microsoft Learn field guide for SecOps investigations

Condensed, non-verbatim operational guide

Purpose	Quick-reference guide for identifying, scoping, investigating, remediating, and documenting suspected phishing incidents in Microsoft 365 environments.
Primary audience	SecOps analysts, incident responders, identity administrators, messaging administrators, and IT operations teams.
Reference source	https://learn.microsoft.com/en-us/security/operations/incident-response-playbook-phishing
Generated	2026-07-02
Use note	
This document is a condensed field guide based on Microsoft Learn guidance. Use the linked Microsoft Learn article as the authoritative source for the latest product-specific details, portal paths, role requirements, and command syntax.	

Prepared for: Muataz Awad | Microsoft Security customer-facing readiness

1. Investigation objective and expected outcome

The investigation should establish whether a suspected phishing message reached users, whether anyone interacted with it, whether it led to identity or endpoint compromise, and what remedial actions are required to reduce further risk.

Outcome statement

At the end of the investigation, the analyst should be able to clearly answer: What message started the incident? Who received it? Who interacted with it? What mailbox, identity, endpoint, or application activity followed? What remediation was completed? What evidence supports the final verdict?

2. At-a-glance workflow

Step	Phase	Focus
1	Scope the reported message	Collect sender, recipient, subject, Message-ID, raw headers, URL/attachment indicators, report context, and delivery status.
2	Identify affected recipients	Use message trace and email investigation data to determine who received the same or similar messages and whether mail was delivered, quarantined, junked, or removed.
3	Review mailbox evidence	Check mailbox access, forwarding, delegated access, Inbox rules, deleted items, and transport/mail flow rules for suspicious persistence or tampering.
4	Analyze interaction and payload	Determine whether users opened/read the message, selected links, opened attachments, executed payloads, or submitted credentials.
5	Correlate identity and endpoint signals	Review Microsoft Entra sign-ins, audit logs, risky user/sign-in data, endpoint evidence, source IPs, user agents, device IDs, and app activity.
6	Remediate and document	Remove malicious mail, block indicators, reset or revoke access when needed, address mailbox persistence, and document findings, timeline, impact, and lessons learned.

3. Readiness prerequisites

Account details: Have at least one identifier for the suspected user or target account: username, UPN, alias, or email address.

Mailbox auditing: Confirm mailbox auditing on by default is enabled so mailbox access and actions are recorded.

Message trace: Use message trace to identify the original source, intended recipients, delivery status, routing details, and Message-ID values.

Unified audit log: Ensure investigators can search user and administrative activity across Microsoft 365 workloads.

Microsoft Entra logs: Confirm sign-in and audit logs are available for the relevant retention window; export to Sentinel, Azure Monitor, or SIEM where longer retention is required.

Roles and access: Ensure the investigation account has appropriate security, compliance, messaging, identity, and endpoint visibility for the scope of the incident.

Defender/Sentinel access: Confirm access to Microsoft Defender XDR, Microsoft Defender for Office 365, Microsoft Defender for Endpoint, Microsoft Entra, and Microsoft Sentinel where applicable.

4. Investigation checklist

Initial message and recipient scope

- ☐ Review the initial phishing email and preserve raw headers.
- ☐ Capture sender, recipient, subject, Message-ID, URLs, attachments, and report source.
- ☐ Get the full set of users who received the same or similar email.
- ☐ Determine delivery outcome for each recipient: delivered, junked, quarantined, failed, or removed.

Mailbox and mail-flow review

- ☐ Check latest mailbox access and suspicious mailbox operations.
- ☐ Review delegated access, mailbox forwarding, Inbox rules, and recently created or modified rules.
- ☐ Review Exchange transport/mail flow rules for suspicious changes or abuse.
- ☐ Validate whether messages were deleted, moved, hidden, or forwarded.

Content, click, and payload analysis

- ☐ Determine whether users read or opened the email.
- ☐ Analyze attachments for malware or payload execution indicators.
- ☐ Check email headers to validate the true source and authentication results.
- ☐ Verify URLs and IPs against threat intelligence and reputation signals.
- ☐ Determine whether users selected links or submitted information.

Identity, endpoint, and app correlation

- ☐ Review Microsoft Entra sign-in logs for suspicious IPs, devices, user agents, locations, and authentication methods.
- ☐ Check audit logs for MFA changes, password changes, app consent, mailbox changes, and administrative activity.
- ☐ Identify the endpoint where the email was opened or attachment executed.
- ☐ Correlate endpoint detections, browser activity, network connections, and cloud app activity.

Remediation and closure

- ☐ Remove or quarantine malicious messages at scale.
- ☐ Block malicious senders, domains, URLs, files, or IPs where appropriate.
- ☐ Disable compromised accounts or reset passwords when needed.
- ☐ Revoke active sessions/refresh tokens and require re-authentication where compromise is suspected.
- ☐ Remove malicious mailbox rules, forwarding, delegated access, or persistence artifacts.
- ☐ Document evidence, timeline, impact, containment actions, and post-incident improvements.

5. Detailed investigation guidance

5.1 Start with the reported message

- Preserve the user report and original message if available. Capture headers rather than relying only on what appears in the client UI.
- Record the Message-ID, Internet message headers, sender display name, envelope sender, return-path, reply-to, recipient list, subject, attachment names/ hashes, URLs, and any associated threat detection verdicts.
- Use the message evidence to pivot into message trace, Explorer, campaigns, email entity details, advanced hunting, and audit logs.

5.2 Build recipient and delivery scope

- Search for the same Message-ID and related sender/subject/URL/attachment patterns to identify all recipients.
- Separate received, blocked, quarantined, junked, ZAPed, or failed delivery outcomes so impact is not overstated.
- Prioritize users who received the email and interacted with links or attachments.

5.3 Check mailbox persistence

- Review forwarding settings, Inbox rules, delegated mailbox access, mailbox permissions, and mailbox audit activity.
- Look for rules that move messages to hidden or low-visibility folders, forward to external addresses, delete messages, or suppress alerts.
- Remove malicious persistence and document the rule name, created/modified time, creator if available, and affected mailbox.

5.4 Confirm user interaction

- Determine whether users opened or read the message through audit and email telemetry where available.
- Check Safe Links, browser, endpoint, proxy, or network telemetry to identify URL clicks and destination activity.
- For attachments, correlate email evidence with endpoint detections, file creation, process execution, and malware verdicts.

5.5 Correlate identity compromise signals

- Review sign-in logs after the email was delivered for impossible travel, unfamiliar IPs, unknown devices, legacy protocols, token/device code flow abuse, or atypical authentication results.
- Check recent MFA method additions, password resets, app consent grants, service principal activity, mailbox settings changes, and risky user/sign-in detections.
- If account compromise is suspected, follow containment steps appropriate for the customer environment and preserve evidence before resetting or cleaning up where required by policy.

6. Handy command and query starting points

Reminder

Validate command syntax against the latest Microsoft Learn docs before running in a customer tenant. Scope permissions and use least privilege.

Use case	Example	Why it matters
Check mailbox auditing default	Get-OrganizationConfig Format-List AuditDisabled	False indicates mailbox auditing is enabled organization-wide.

Message trace by sender/recipient/date	Get-MessageTrace -SenderAddress <sender> -RecipientAddress <recipient> -StartDate <start> -EndDate <end>	Use message trace to investigate routing, delivery, and recipient scope.
Review Inbox rules	Get-InboxRule -Mailbox <user@domain.com> Format-Table Name,Enabled,Priority,Description -Auto	Look for suspicious forwarding, move, delete, or hide logic.
Check mailbox forwarding	Get-Mailbox <user@domain.com> Format-List ForwardingSmtpAddress,ForwardingAddress,DeliverToMailboxAndForward	Unexpected forwarding may indicate persistence.
Revoke user sign-in sessions	Revoke-MgUserSignInSession -UserId <user-id-or-upn>	Use when identity compromise is suspected and re-authentication is required.

7. Evidence matrix

Question	Helpful evidence sources
Was the email delivered?	Message trace, Defender email entity, Explorer, quarantine logs
Who received it?	Message trace, Explorer, campaign view, advanced hunting
Did the user open/read it?	Mailbox audit, email events, client activity telemetry where available
Was a URL clicked?	Safe Links click data, endpoint/browser telemetry, network/proxy logs, sign-in correlation
Did an attachment execute?	Attachment analysis, malware verdicts, endpoint file/process/network telemetry
Was mailbox persistence added?	Mailbox forwarding settings, Inbox rules, delegated access, mailbox audit log
Was identity compromised?	Microsoft Entra sign-in logs, audit logs, risky users/sign-ins, MFA and app consent changes
Was impact contained?	Mail removal status, block/allow list updates, account/session controls, endpoint remediation state

8. Closure notes template

- ☐ Incident summary: short description of what happened and how it was reported.
- ☐ Timeline: first observed, delivery time, user interaction time, detection time, containment time, remediation time.
- ☐ Scope: affected users, mailboxes, endpoints, applications, and messages.
- ☐ Evidence reviewed: message headers, message trace, Defender evidence, audit logs, sign-ins, endpoint telemetry, hunting queries.
- ☐ Verdict: malicious, suspicious, benign, or inconclusive with rationale.
- ☐ Actions completed: mail removal, block actions, mailbox rule cleanup, sign-out/session revocation, password/MFA actions, endpoint cleanup.
- ☐ Follow-up recommendations: detection tuning, user training, CA/authentication controls, reporting process improvements, logging/retention gaps.

9. Authoritative source

Microsoft Learn article: [Phishing investigation | Microsoft Learn](#)

This field guide does not replace the official Microsoft Learn article. Always reference the source for the latest workflow images, prerequisites, role/permission details, portal locations, and product-specific guidance.